

Advanced Cyber Security Assignment

Report: DMZ-to-LAN APM Bridge

Cover Page

- **Course Title & Code:** Advanced Cyber Security — SS ZG681 / SE ZG681
- **Student Names:** Saptarsi Roy & Girish Amrutesh Joshi
- **Evaluation Component:** EC-1 Expanded Situated Learning Project
- **System Selected:** DMZ-to-LAN APM Bridge
- **System Type:** Anonymized / Simulated Enterprise Architecture
- **Industry Domain:** Cybersecurity & Enterprise Systems

Confidentiality Statement

This report contains proprietary and confidential security assessment and architectural design data for the **DMZ-to-LAN APM Bridge** system. Disclosure, copying, or distribution of this material without prior authorization from the Cybersecurity and Infrastructure Engineering teams is strictly prohibited. All internal network topographies, hostnames, IP addresses, vendor specifics, and security findings have been safely abstracted and generalized using safe placeholders in accordance with BITS Pilani confidentiality guidelines.

Executive Summary

Modern enterprise environments mandate real-time observability across customer-facing web applications deployed within Demilitarized Zones (DMZ). However, bridging telemetry streams from an exposed DMZ into an internal Local Area Network (LAN) introduces critical cybersecurity risks. The **DMZ-to-LAN APM Bridge** system is designed to provide high availability, throughput monitoring, and SLA compliance tracking without allowing the APM monitoring conduit to become a vector for lateral network movement or Remote Code Execution (RCE) attacks.

Through a comprehensive security risk assessment, two primary threat scenarios were identified: **Lateral Pivot Attacks** via misconfigured firewall rules and **Malicious Telemetry Injection** leveraging unvalidated log parsing engines. To mitigate these risks, this system adopts a multi-phased Defense-in-Depth posture—combining unidirectional network enforcement (data diodes/NGFW), Mutual TLS (mTLS) authentication, strict schema validation, and Zero-Trust data governance.

B.2 Anchor: System and Threat Surface Blueprinting

1. System Description & Runtime Architecture

The DMZ-to-LAN APM Bridge facilitates centralized application monitoring across two primary security domains:

- **DMZ Network Zone (Semi-Trusted / Untrusted Exposure):** Hosts customer-facing applications and lightweight APM Probes. These probes collect performance metrics, system metadata, and transaction headers.
- **Firewall Conduit / Data Boundary:** Enforces strict boundary rules where data is pushed exclusively from the DMZ to the LAN over **HTTPS / TLS 1.3 (Port 443)**.
- **Internal Core LAN Zone (Trusted):** Houses the internal APM Ingestion Service, Processing Engine, and Telemetry Databases.

2. C4 Architecture Diagrams

C4 Level 1 — System Context Diagram

Code snippet

```
@startuml
title C4 Level 1 · System Context Diagram: DMZ-to-LAN APM Bridge

top to bottom direction
skinparam componentStyle rectangle

skinparam rectangle {
    BackgroundColor<<person>> #08427B
    FontColor<<person>> #FFFFFF
    BorderColor<<person>> #052E56

    BackgroundColor<<system>> #1168BD
    FontColor<<system>> #FFFFFF
    BorderColor<<system>> #0B4884

    BackgroundColor<<ext_system>> #888888
    FontColor<<ext_system>> #FFFFFF
    BorderColor<<ext_system>> #555555
}

rectangle "SRE & NOC Operators\n[Person]\nMonitors availability, latency, system alerts, and SLA dashboards." as sre_noc <<person>>
rectangle "Security Analysts\n[Person]\nAudits telemetry integrity, access controls, and data flow logs." as sec_analyst <<person>>
rectangle "Application Owners\n[Person]\nReviews application performance, error rates, and compliance reports." as app_owner <<person>>

rectangle "DMZ-to-LAN APM Bridge\n[Software System]\nSecurely bridges performance telemetry from DMZ hosts to internal core LAN databases." as apm_bridge <<system>>

rectangle "DMZ Web Applications\n[External System]\nCustomer-facing web applications and backend nodes hosted in the DMZ." as dmz_apps <<ext_system>>

dmz_apps --> apm_bridge : "Pushes performance metrics & trace headers\n[HTTPS / TLS 1.3 (Port 443)]"
sre_noc --> apm_bridge : "Views system health & receives operational alerts\n[HTTPS / Web UI]"
```

```
sec_analyst --> apm_bridge : "Audits access control & FIM security
logs\n[HTTPS / SIEM Integrations]"
app_owner --> apm_bridge : "Reviews SLA compliance & performance
metrics\n[HTTPS / Dashboard]"
```

```
@enduml
```

C4 Level 2 — Container Diagram

Code snippet

```
@startuml
title C4 Level 2 · Container Diagram: DMZ-to-LAN APM Bridge Architecture

top to bottom direction
skinparam componentStyle rectangle

skinparam rectangle {
    BackgroundColor<<person>> #08427B
    FontColor<<person>> #FFFFFF
    BorderColor<<person>> #052E56

    BackgroundColor<<container>> #438DD5
    FontColor<<container>> #FFFFFF
    BorderColor<<container>> #2E6295

    BackgroundColor<<db>> #438DD5
    FontColor<<db>> #FFFFFF
    BorderColor<<db>> #2E6295
}

rectangle "Operations & Security Staff\n[Person]\nSREs, NOC, Security
Analysts" as operators <<person>>

package "DMZ Zone (Semi-Trusted Network)" {
    rectangle "DMZ APM Probe Agent\n[Container: Agent / Collector]\nGathers
latency, availability metrics, throughput, and headers." as dmz_probe
    <<container>>
}

package "Firewall Conduit / Security Boundary" {
    rectangle "NGFW / Data Diode Conduit\n[Container: Network Security
Control]\nRestricts traffic strictly to unidirectional PUSH (DMZ to LAN) on
Port 443." as fw_conduit <<container>>
}
```

```

package "Core Internal LAN Zone (Trusted Network)" {
    rectangle "APM Ingestion Service\n[Container: Java / Spring Boot or Go]\nTerminates mTLS, validates payload schema, and redacts PII/malicious inputs." as ingestion_svc <<container>>
    rectangle "APM Processing Engine\n[Container: Backend Processing Service]\nCalculates metrics, evaluates SLA breaches, and generates alert streams." as apm_engine <<container>>
    database "APM Telemetry Storage\n[Container: Time-Series / Relational DB]\nStores metric history, system metadata, and sanitized trace headers." as apm_db <<db>>
    rectangle "APM Operational UI\n[Container: React / Node.js Web App]\nProvides visual dashboards, performance charts, and alert management." as dashboard <<container>>
}

dmz_probe --> fw_conduit : "Pushes encrypted metric stream\n[HTTPS / mTLS 1.3]"
fw_conduit --> ingestion_svc : "Forwards packet stream via uni-directional rule\n[HTTPS / Port 443]"
ingestion_svc --> apm_engine : "Passes validated & sanitized telemetry\n[Internal gRPC / Queue]"
apm_engine --> apm_db : "Stores metrics, logs, and metadata\n[Encrypted DB Connection]"
operators --> dashboard : "Views dashboards and configures alerts\n[HTTPS]"
dashboard --> apm_db : "Queries telemetry data for reports\n[SQL / TSDB API]"

@enduml

```

C4 Level 3 — Component Diagram for Ingestion Service

Code snippet

```

@startuml
title C4 Level 3 · Component Diagram: Ingestion Service (Internal Core LAN)

top to bottom direction
skinparam componentStyle rectangle

skinparam rectangle {
    BackgroundColor<<container>> #438DD5
    FontColor<<container>> #FFFFFF
}

```

```

    BorderColor<<container>> #2E6295

    BackgroundColor<<component>> #85BBF0
    FontColor<<component>> #000000
    BorderColor<<component>> #5D82A8
}

rectangle "Firewall Conduit\n[Container: NGFW / Data Diode]\nPushes incoming
HTTPS streams from DMZ probes." as fw_conduit <<container>>
rectangle "APM Processing Engine\n[Container: Backend Engine]\nProcesses
clean metrics and evaluates SLAs." as apm_engine <<container>>

package "APM Ingestion Service" {
    rectangle "mTLS Endpoint Listener\n[Component: Netty / TLS 1.3
Engine]\nTerminates mTLS connection and enforces probe client certificate
verification." as tls_endpoint <<component>>
    rectangle "Rate Limiter & IP Whitelisting\n[Component: Token
Bucket]\nEnforces strict IP white-listing and protects against telemetry
flood DoS attacks." as rate_limiter <<component>>
    rectangle "Schema & Input Validator\n[Component: JSON / Proto Schema
Engine]\nValidates payload structure and blocks malformed data (prevents
Log4j / RCE)." as schema_validator <<component>>
    rectangle "PII Redaction & Sanitizer\n[Component: Regex / Masking
Module]\nScans transaction headers for PII and redacts sensitive data for
GDPR." as pii_sanitizer <<component>>
    rectangle "Ingestion Buffer Forwarder\n[Component: Queue
Producer]\nBuffers sanitized payloads and pushes them to the internal engine
queue." as queue_publisher <<component>>
}

fw_conduit --> tls_endpoint : "Delivers encrypted payload\n[HTTPS / mTLS
1.3]"
tls_endpoint --> rate_limiter : "Passes request context"
rate_limiter --> schema_validator : "Forwards connection stream"
schema_validator --> pii_sanitizer : "Sends structurally validated telemetry
payload"
pii_sanitizer --> queue_publisher : "Sends sanitized telemetry object"
queue_publisher --> apm_engine : "Publishes clean event stream\n[Internal
Queue / gRPC]"

@enduml

```

3. Data Flow Mapping

Flow ID	Source	Destination	Data Element	Protocol / Port	Security Controls
DF-01	DMZ Application Host	DMZ APM Probe Agent	Latency metrics, CPU/memory stats, request throughput, and trace headers	Local IPC / Loopback	Process isolation, least privilege agent execution
DF-02	DMZ APM Probe Agent	Firewall Conduit (NGFW)	Batched telemetry JSON/Protobuf packets	HTTPS / Port 443	Outbound-only DMZ connection, TLS 1.3 encryption
DF-03	Firewall Conduit (NGFW)	APM Ingestion Service (LAN)	Encrypted stream forwarded across trust boundary	HTTPS / Port 443	Unidirectional data push rule, IP white-listing
DF-04	APM Ingestion Service	APM Processing Engine	Validated and PII-redacted metric stream	Internal gRPC / Queue	mTLS, strict JSON schema validation, regex PII redaction
DF-05	APM Processing Engine	Telemetry Database	Processed performance metrics and system metadata	Encrypted DB Protocol (Port 5432 / 9200)	AES-256 encryption at rest, database RBAC

DF-06	Telemetry Database	Operational Dashboard	Metric history and SLA compliance views	HTTPS / Port 443	Web RBAC, session-based authentication
--------------	--------------------	-----------------------	---	------------------	--

4. Data Classification Matrix

Data Asset	Data Elements	Classification	Compliance Relevance	Handling & Storage Requirements
Performance Metrics	Latency, response times, throughput, CPU/memory utilisation	Internal	Operational SLAs	Encrypted in transit (TLS 1.3), standard retention policy.
System Metadata	Hostnames, OS versions, agent IDs, internal IP addresses	Restricted / Confidential	Internal Security Policy	Masked in non-admin views, restricted query access.
Transaction Trace Headers	HTTP headers, URL paths, correlation IDs, user-agent strings	Confidential	GDPR / Privacy Regulations	Automated regex scanning for PII, redaction before storage.

Security Audit Logs	Ingestion logs, failed mTLS handshakes, FIM triggers	Restricted	SOC 2, ISO 27001	Immutable storage, forwarded to SIEM, 90-day minimum retention.
----------------------------	--	-------------------	------------------	---

5. Business and Operational Importance

Business Function	Operational Description	Business Importance & Security Impact
Real-time Availability Tracking	Continuous monitoring of uptime, node health, and service accessibility across DMZ application hosts.	High Business Impact: Prevents undetected service outages on customer-facing platforms. Ensures operational teams (NOC/SRE) receive rapid degradation alerts.
Latency & Throughput Monitoring	Captures response times, payload throughput, transaction trace headers, and bottleneck metrics.	Medium-High Impact: Maintains optimal user experience. Corrupt or forged metrics directly impact capacity planning and system auto-scaling integrity.
SLA Compliance Reporting	Aggregates availability and response time data against legally binding and internal Service Level Agreements.	High Business & Legal Impact: Drives contract compliance. PII exposure in trace headers introduces GDPR non-compliance penalties.
Cross-Domain Risk Containment	Isolates the internal core LAN from compromised	Critical Security Importance: Prevents lateral pivot attacks from a compromised web node into

	DMZ hosts while enabling observability.	core database and business systems.
--	---	-------------------------------------

B.3 Apply: Advanced Cyber Security Engineering Pipeline

Task 1: CIA Asset Valuation, Security Models & Cryptographic Policy

CIA Analysis

Security Pillar	Target Level	Threat / Impact Scenario	Mitigation Strategy
Confidentiality	Low-to-Medium	Leaking sensitive application structure, internal IP schemes, or user PII in trace headers.	Strict data redaction in Ingestion Service, TLS 1.3 transit encryption, RBAC on dashboard.
Integrity	High	Telemetry injection or packet alteration causing false alerts or masking real service outages.	mTLS probe authentication, schema payload validation, file integrity monitoring (FIM).
Availability	Medium	Telemetry flood DoS attacks or ingestion service failure blinding NOC/SRE teams.	Ingestion rate limiting, asynchronous message queue buffering, auto-scaling ingestion nodes.

Security Models Selection

- **Network Boundary Model:** Unidirectional Next-Gen Firewall (NGFW) or physical Data Diode.
- **Application Layer Model:** Defense-in-Depth pipeline utilizing mTLS, Schema Validation, and Regex PII Sanitization.
- **Identity & Access Model:** Zero Trust Architecture (ZTA) enforcing client certificate validation for agents and Role-Based Access Control (RBAC) for operators.

Cryptographic Policy

Domain	Protocol / Standard	Technical Requirement	Operational Purpose
Data in Transit	TLS 1.3 / mTLS	Mutual authentication using TLS 1.3 with AES-256-GCM or ChaCha20-Poly1305 cipher suites. Weak ciphers disabled.	Secures telemetry streams across trust boundaries and validates probe identity.
Data Integrity Verification	HMAC-SH A256	SHA-256 keyed-hash message authentication code (HMAC) generated at the probe level.	Guarantees payload authenticity and detects tampering prior to parsing.
Data at Rest	AES-256-X TS / CBC	Disk-level and column-level encryption using AES-256 for time-series telemetry databases.	Protects stored metrics, system metadata, and transaction logs from unauthorized access.
Key Management	PKI / HSM / KMS	Centralized Key Management Service (KMS) or Hardware Security Module (HSM). Automated 90-day rotation.	Enforces key lifecycle management, secure storage, and strict rotation schedules.

Task 2: Multi-Stage Threat Vectors and Attack Graphs

STRIDE Threat Analysis

STRIDE Category	Threat Description	Vulnerable Component	Technical Impact	Architectural Mitigation Control
Spoofing	Attacker impersonates a legitimate DMZ APM probe to send rogue metrics.	Ingestion Service TLS Endpoint	Unauthorized system access, rogue data injection.	Enforce mutual TLS (mTLS) with client certificate verification and strict IP whitelisting.
Tampering	Interception or modification of telemetry data in transit between DMZ and LAN.	Network Transport (Port 443)	Metric alteration, false alert generation.	TLS 1.3 encryption in transit, HMAC payload integrity signatures.
Repudiation	Unauthenticated agent actions or unlogged configuration modifications in DMZ.	DMZ APM Probe Agent	Lack of auditability during post-incident analysis.	Centralized immutable audit logging, File Integrity Monitoring (FIM).
Information Disclosure	Unsanitized transaction headers leaking PII or internal IP topologies.	Ingestion Engine / Telemetry DB	GDPR compliance violations, network reconnaissance mapping.	Automated regex scanning for PII redaction and header sanitization prior to database storage.

Denial of Service	Telemetry packet flooding originating from compromised DMZ hosts.	Ingestion Service Listener	Consumption of ingestion buffer, APM service crash.	Ingestion rate limiting, token bucket controls, asynchronous queue buffering.
Elevation of Privilege	Exploiting unvalidated parser inputs (e.g., Log4j) to execute remote commands.	APM Ingestion Engine	Remote Code Execution (RCE), full LAN server compromise.	Schema validation, principle of least privilege execution, RASP enforcement.

Threat Scenario 1: Lateral Pivot Attack via DMZ Node Compromise

- **Threat Summary:** An external attacker gains initial access to a public web application in the DMZ and uses the APM monitoring agent connection to tunnel into the core LAN.
- **Primary Root Cause:** Misconfigured network boundary allowing bidirectional traffic or command execution channels between DMZ and LAN.

Attack Graph Table

Step ID	Attacker Phase	Action Description	Compromised Target / Vector	Security Control Bypassed
TS1-01	Reconnaissance & Initial Access	Exploits public-facing web vulnerability to gain local code execution.	DMZ Web Application	WAF / Web Application Hardening

TS1-02	Discovery & Privilege Escalation	Discovers local APM Probe Agent and network connections bridging DMZ to LAN.	DMZ Host & APM Probe Agent	Local OS Privilege Controls
TS1-03	Lateral Movement (Pivot)	Hijacks the agent connection or uses bi-directional firewall rules to tunnel into the internal LAN.	DMZ-to-LAN Firewall Conduit	Permissive / Bi-directional Firewall Rules
TS1-04	Internal Infrastructure Access	Obtains access to the internal APM Ingestion Server and executes commands.	Internal Core LAN APM Server	Network Micro-segmentation & Zero Trust

PlantUML Attack Graph

Code snippet

```

@startuml
title Threat Scenario 1: Lateral Pivot Attack Graph

skinparam ActivityBackgroundColor #FFF0F0
skinparam ActivityBorderColor #CC0000
skinparam ArrowColor #CC0000

start
:External Attacker targets public application;

```

```
:Exploit Web Vulnerability (Initial Access) on DMZ Node;
note right: Initial Compromise in DMZ Zone

:Gain shell access on DMZ Application Host;
:Discover APM Probe Agent & active connection to LAN;

if (Firewall Enforcement?) then (Bi-directional / Misconfigured)
  :Establish Tunnel / Reverse Shell via APM Monitoring Port;
  :Lateral Movement across Firewall Conduit into Internal LAN;
  :Compromise Internal Core APM Server;
  :Lateral Movement to Internal Data Stores;
  stop
else (Strict Unidirectional Push / Data Diode)
  :Attempt Inbound LAN Connection;
  -[#green]-> Blocked by Firewall Rule / Data Diode;
  :Attack Contained within DMZ Zone;
end
endif

@enduml
```

Threat Scenario 2: Malicious Telemetry Payload Injection

- **Threat Summary:** An attacker intercepts or compromises a DMZ probe to inject malformed payloads (e.g., Log4j / RCE strings) into the telemetry stream, triggering code execution in the internal parsing engine.
- **Primary Root Cause:** Lack of payload input validation and schema enforcement at the internal APM ingestion layer.

Attack Graph Table

Step ID	Attacker Phase	Action Description	Compromised Target / Vector	Security Control Bypassed

TS2-01	Telemetry Manipulation	Injects malicious string (e.g., Log4j / RCE exploit) into HTTP trace headers or metric fields.	DMZ Telemetry Stream / Probe Agent	Agent Payload Integrity Check
TS2-02	Evasion & Transport	Transmits crafted payload via legitimate outbound HTTPS monitoring stream.	Outbound HTTPS Port 443	Boundary Transport Security (Passes standard TLS)
TS2-03	Ingestion Payload Processing	Ingestion Service receives payload without enforcing schema validation or string sanitization.	APM Ingestion Service	Schema Validation & Input Sanitization
TS2-04	Execution & Impact	Malicious string triggers parser vulnerability, executing arbitrary code or corrupting DB state.	APM Storage Engine / Database	Runtime Application Self-Protection (RASP)

PlantUML Attack Graph

Code snippet

```
@startuml
title Threat Scenario 2: Malicious Telemetry Payload Injection Graph
```

```

skinparam ActivityBackgroundColor #FFF0F0
skinparam ActivityBorderColor #CC0000
skinparam ArrowColor #CC0000

start
:Attacker crafts malicious telemetry payload;
note right: Embeds exploit (Initial Access / RCE string) in trace headers

:Probe Agent transmits payload via HTTPS (Port 443);
:Payload passes Firewall Conduit (Legitimate Outbound Traffic);
:Payload arrives at Internal APM Ingestion Service;

if (Ingestion Layer Defense?) then (No Schema Validation / Plain Parsing)
  :Parser executes malicious string during payload processing;
  :Remote Code Execution (RCE) triggered on Ingestion Node;
  :Attacker gains elevated access to Internal APM Database;
  :Telemetry Data Corrupted / Monitoring Blind Spot Created;
  stop
else (mTLS + Strict Schema Validation + PII Redaction)
  :Schema Validator detects malformed payload structure;
  :PII Redactor strips/sanitizes malicious strings;
  -[#green]-> Payload Dropped & Security Alert Generated;
  :Internal Core LAN Protected;
  end
endif

@enduml

```

Task 3: Defense-in-Depth Infrastructure Design

Layered Security Control Architecture

Architectural Layer	Defense Control	Technical Implementation	Security Objective

Network Layer Control	Unidirectional Traffic Policy	Uni-directional Data Diodes or restricted Next-Generation Firewall (NGFW) rules configured strictly for DMZ-to-LAN PUSH traffic.	Eliminates inbound network connectivity from the internal LAN to the DMZ, preventing attackers from establishing reverse tunnels.
Application Layer Control	Mutual Authentication & Schema Validation	Mutual TLS (mTLS) for all probe-to-engine communication alongside strict JSON/Protobuf schema validation on ingestion nodes.	Enforces agent identity verification and blocks malformed telemetry payloads containing Log4j or buffer overflow exploits.
Admin Layer Control	Access Governance & Host Integrity	Role-Based Access Control (RBAC), Least Privilege policies for monitoring agents, and automated File Integrity Monitoring (FIM).	Prevents unauthorized binary modification of probes and ensures administrative actions adhere to strict least-privileges.

Defense Architecture (PlantUML)

Code snippet

```
@startuml
!include
https://raw.githubusercontent.com/plantuml-stdlib/C4-PlantUML/master/C4_Deployment.puml

title Defense Architecture: DMZ-to-LAN APM Bridge
```

```

Deployment_Node(dmz, "DMZ Network Domain (Semi-Trusted)", "Network
Isolation Zone") {
    Deployment_Node(app_server, "DMZ Host Server", "Linux /
Container Host") {
        Container(app, "Web Application", "Node.js / Java /
Python")
        Container(probe, "APM Probe Agent", "Go / C++ Agent",
"Collects performance metrics & trace headers")
    }
}

Deployment_Node(firewall_zone, "Security Perimeter / Firewall
Layer") {
    Container(ngfw, "Next-Gen Firewall / Data Diode", "Hardware /
Virtual Appliance", "Enforces strict DMZ-to-LAN Push rules. Blocks
LAN-to-DMZ inbound probes.")
}

Deployment_Node(lan, "Internal Core LAN Domain (Trusted)", "Core
Network Infrastructure") {
    Deployment_Node(ingestion_cluster, "Ingestion Service Cluster",
"Kubernetes / Linux Server") {
        Container(mtls, "mTLS & Rate Limiter", "Envoy / NGINX",
"Terminates mTLS & enforces rate limits")
        Container validator, "Schema & PII Sanitizer", "Spring Boot
Service", "Validates payload structure & scrubs PII")
    }

    Deployment_Node(processing_cluster, "Processing Engine Node",
"App Cluster") {
        Container(engine, "APM Core Engine", "Java / Go
Microservice", "Calculates metrics & evaluates SLAs")
    }
}

```

```

Deployment_Node(storage_node, "Secure Storage Cluster",
"Database Infrastructure") {
  ContainerDb(tsd, "Telemetry Database", "Encrypted
Time-Series DB", "AES-256 Encrypted Storage")
}
}
Rel(app, probe, "Gathers execution trace & performance stats",
"Local IPC")
Rel(probe, ngfw, "Pushes encrypted metrics", "HTTPS / mTLS 1.3 /
Port 443")
Rel(ngfw, mtl, "Unidirectional push forwarding", "HTTPS / Port
443")
Rel(mtl, validator, "Passes verified stream", "Internal gRPC")
Rel(validator, engine, "Forwards clean, sanitized telemetry",
"Buffered Event Queue")
Rel(engine, tsdb, "Writes metrics and SLA logs", "Encrypted DB
Connection")
@enduml

```

B.4 Analyse: Gap Analysis and CVSS Risk Quantification

1. Gap Analysis

Current State Architecture	Identified Security Gap	Targeted Future State Architecture	Risk Severity
Standard TLS with single-ended server verification.	Risk of rogue agent spoofing or unauthorized DMZ endpoint pushing metrics.	Mutual TLS (mTLS) requiring two-way certificate validation for all DMZ probes.	High

Plain JSON parsing without strict schema checks.	Ingestion service vulnerable to payload injection exploits (RCE / Log4j).	Mandatory schema validation and input sanitization layer prior to engine processing.	Critical
Permissive bidirectional firewall port rules.	Potential lateral pivot path from compromised DMZ hosts into core LAN servers.	Unidirectional Push policy enforced by NGFW or physical Data Diode.	Critical
Full HTTP trace header logging to storage.	Unintentional storage of user PII in transaction logs violating privacy norms.	Automated regex-based PII redaction module integrated into Ingestion Service.	Medium

2. CVSS v3.1 Risk Quantification

Vulnerability 1: Lateral Pivot via Misconfigured Firewall (Threat Scenario 1)

- **CVSS v3.1 Vector String:** `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H`
- **Base Score: 10.0 (Critical)**
- **Justification:** An unauthenticated attacker over the network can exploit vulnerable DMZ applications, compromise the probe host, and leverage permissive network access to gain full control over internal core LAN systems (Scope Changed, High impact to Confidentiality, Integrity, and Availability).

Vulnerability 2: Remote Code Execution via Malicious Payload (Threat Scenario 2)

- **CVSS v3.1 Vector String:** `CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H`
- **Base Score: 8.8 (High)**
- **Justification:** An attacker with access to transmit metrics from a DMZ probe (Low Privileges Required) can send a malformed payload that triggers an unvalidated parser in the internal LAN ingestion engine, leading to full internal host compromise (High impact across CIA).

3. Leadership Risk Interpretation

For executive leadership, the identified vulnerabilities represent a direct threat to core operational stability. Without intervention, an incident originating in an exposed public-facing server could pivot directly into internal corporate data stores, leading to full internal network compromise or severe regulatory fines under GDPR for PII leakage. Implementing the proposed defenses reduces the CVSS exposure from 10.0 (Critical) to an acceptable residual risk profile.

B.5 Reflect: Enterprise Constraints and Lifecycle Maintenance

1. Enterprise Constraints

Constraint Domain	Description	Architectural Impact / Operational Trade-off
Performance & Latency	High-volume telemetry stream inspection must not exceed SLA response limits.	Inspection, mTLS decryption, and schema validation must be optimized to prevent ingestion latency bottlenecks.
Management & Remote Control	Unidirectional network policy prevents outbound management connections to DMZ.	Inability to push remote agent updates or configuration changes directly from internal management consoles.
Cost & Complexity	Budgetary limits for dedicated hardware appliances (e.g., physical Data Diodes).	Requires leveraging existing NGFW virtual appliances with strict rule sets rather than specialized hardware.
Regulatory & Compliance	Data retention and privacy mandates (GDPR, ISO 27001).	Requires strict operational auditing and automated scrubbing of sensitive trace header data.

2. High-Impact Immediate Remediation

Remediation Item	Target Risk	Priority	Implementation Timeline	Estimated Effort
Reconfigure Firewall Rules	Lateral Pivot Attack	P0 (Critical)	Days 1–7	Low (Configuration Change)
Deploy Payload Schema Validation	Telemetry Injection / RCE	P0 (Critical)	Days 8–15	Medium (Software Module Integration)
Enforce Probe IP Whitelisting	Agent Spoofing / DoS	P1 (High)	Days 16–20	Low (Network ACL Updates)
Integrate PII Regex Redaction	GDPR Non-Compliance	P1 (High)	Days 21–30	Medium (Software Update)

3. Security Reflection & Thinking Evolution

Initial architectural assessments often treat application performance monitoring as a passive, low-risk operational tool. However, security analysis demonstrates that telemetry streams crossing trust boundaries represent high-value attack vectors. Unsanitized ingestion pipelines and permissive network paths turn monitoring channels into primary paths for lateral network pivot attacks and supply-chain compromises. Securing cross-domain bridges requires moving from perimeter-only trust to continuous Zero-Trust verification.

References and Assumptions

Technical Assumptions

- **Unidirectional Network Capabilities:** The existing Next-Generation Firewall (NGFW) infrastructure supports strict unidirectional state rules (DMZ-to-LAN PUSH) without requiring reverse TCP handshake initiation from internal LAN nodes.
- **DMZ Agent Constraints:** DMZ probe agents operate as lightweight, non-privileged services without local administrative or root rights on host nodes.

- **Resource Allocations:** Ingestion nodes in the internal core LAN are auto-scaled and provisioned with sufficient CPU/RAM overhead to process real-time mTLS decryption, schema verification, and regex sanitization without dropping metric packets.

Architectural & Security References

1. **NIST SP 800-52 Rev. 2:** *Guidelines for the Selection, Configuration, and Use of Transport Layer Security (TLS) Implementations.*
2. **NIST SP 800-53 Rev. 5:** *Security and Privacy Controls for Information Systems and Organizations* (Controls: SC-8 Building Guard Rails, SC-13 Cryptographic Protection, SI-10 Information Input Validation).
3. **OWASP API Security Top 10:** Application Security Vulnerabilities (API3:2023 Broken Object Property Level Authorization, API8:2023 Security Misconfiguration).
4. **C4 Model Standard:** Structuring software architecture representations (Context, Containers, Components, and Code).
5. **FIRST CVSS v3.1 Specification:** Common Vulnerability Scoring System v3.1 Specification Document.